

Reproducing and Evaluating Lightweight Deterministic Detection of Payload-Based Transaction Phishing (PTXPhish) on Ethereum

Reference Paper: NDSS 2025 | Student Roll: 2024UCP1639 | Project Status: Completed Reproduction Artifact

1. Executive Summary & Research Background

In Web3 ecosystems, user private keys remain isolated within hardware or browser wallets. Consequently, attackers exploit **blind signing**: decentralized applications present users with raw, unreadable hexadecimal calldata and 4-byte Keccak function selectors. Users routinely sign malicious payloads assuming legitimate activity (e.g., claiming airdrops or minting tokens). Once confirmed on the Ethereum ledger, these transactions permanently and irreversibly extract assets.

The foundational NDSS 2025 study demonstrated dynamic detection via full EVM state replay simulation on dedicated local archive nodes (>2 TB storage). While effective (>0.99 Macro F1), such infrastructure introduces multi-second latency and high maintenance costs. This project evaluates the empirical boundaries of a zero-simulation, lightweight deterministic heuristic cascade executing over resilient public Web3 archive RPCs.

2. Threat Vector Taxonomy

- 1. Ice Phishing (Token Approval Abuse):** Exploits ERC-20 `approve()` (0x095ea7b3) and ERC-721 `setApprovalForAll()` (0xa22cb465) to grant attacker smart contracts persistent authorization to drain tokens via delayed `transferFrom()` calls. *Risk: CRITICAL.*
- 2. NFT Order Phishing:** Utilizes off-chain EIP-712 signatures within marketplace routers (such as Seaport `fulfillOrder` 0xf0f3ee1 and Uniswap `Permit2`) to sweep high-value digital assets for negligible returns. *Risk: CRITICAL.*
- 3. Address Poisoning Scams:** Attackers generate vanity addresses mirroring the prefix and suffix of a victim counterpart, broadcasting 0-value ERC-20 transfers (0xa9059cbb, value=0) to pollute transaction history and exploit habitual copy-pasting. *Risk: HIGH.*
- 4. Payable Function Scams:** Deceptive contract calls demanding direct native Ether transfers (value > 0) or non-standard interactive payloads where financial loss is strictly bounded to the immediate invocation. *Risk: MODERATE.*

3. System Architecture & Implementation

Resilient RPC Failover Pool: Configured Web3 connections across five public endpoints (ethereum.publicnode.com, rpc.payload.de, cloudflare-eth.com, eth.llamarpc.com, 1rpc.io) with dynamic exception handling and HexBytes casting to eliminate reliance on private archive hardware.

Evaluation Engine (scripts/run_evaluation.py): Executes stratified balanced sampling across ground-truth datasets, queries transaction inputs, runs the 4-tier cascade, and exports structured CSV outputs.

Statistical Visualizer (scripts/generate_metrics.py): Uses scikit-learn, matplotlib, and seaborn to compute balanced accuracy, class-level Precision/Recall/F1 metrics, and generate annotated confusion matrices.

Interactive Dashboard (app.py): A Streamlit application providing sub-second calldata parsing, deterministic risk profiling, and live metric presentation.

4. Empirical Results & Benchmark Comparison

Benchmark Performance: On the balanced N=500 benchmark (125 samples per class, seed=42), the lightweight cascade achieved **88.60% Accuracy** and a **0.89 Macro F1-Score**. Per-class metrics reached 0.99 F1 for NFT Orders, 0.96 F1 for Address Poisoning, 0.81 F1 for Ice Phishing, and 0.79 F1 for Payable Scams.

5. Architectural Discrepancy & Boundary Analysis

The difference between the original paper (>0.99 F1) and our static cascade (0.89 F1) stems from the absence of EVM bytecode execution:

- 1. Proxy Forwarding:** Malicious contracts calling `execute()` route internally via `DELEGATECALL` to hidden approval functions, appearing as generic payable interactions in static calldata.
- 2. Multicall Batching:** Nested operations bundled inside `multicall(bytes[])` mask internal function selectors from outer-payload inspection.
- 3. Zero-ETH Interactive Calls:** Custom claim functions transferring 0 ETH cannot be fully distinguished from benign logic without tracing runtime state modifications.

6. Practical Implications & Conclusion

This reproduction confirms that deterministic calldata parsing can resolve ~89% of attacks in under 200ms at zero infrastructure cost. This architecture enables an effective two-layer wallet defense: an instant client-side static gatekeeper for known exploit patterns, with remote EVM simulation reserved for ambiguous payloads.